

architecture → protocols → attack surface → practical lab → commands → security testing → reporting sab cover karenge.

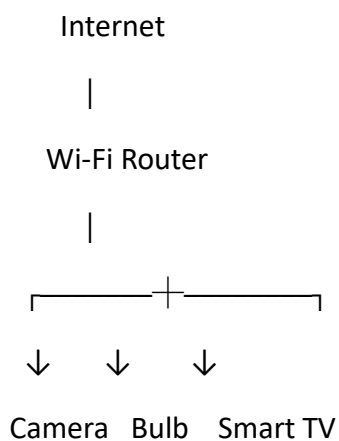
⚠ Practical commands sirf **apne device, CTF, virtual lab, simulator, ya written authorization wale environment** par run karna.

1. Sabse pehle: IoT aur OT exactly kya hain?

IoT = Internet of Things

IoT devices generally physical devices hote hain jo network se connected hote hain aur data collect/send/receive karte hain.

Example:



Example

Tumhare ghar mein Wi-Fi camera hai.

Mobile app:

Mobile



Internet/Wi-Fi



Camera

Mobile se tum camera ka live video dekh rahe ho.

Camera:

- network se connected hai
- username/password use karta hai
- web/API interface ho sakta hai
- firmware hota hai
- kabhi cloud service se connect hota hai

Isliye camera bhi **attack surface** rakhta hai.

2. OT kya hai?

OT ka full form:

Operational Technology

OT ka primary purpose hota hai:

Physical machines/processes ko monitor aur control karna.

Example:

Temperature Sensor

↓

PLC

↓

Motor

PLC temperature read karta hai aur programmed logic ke according motor/valve/pump ko control karta hai.

3. IT vs IoT vs OT

Ye distinction bahut important hai.

Technology	Example	Main purpose
IT	Laptop, Server	Information/Data

Technology	Example	Main purpose
IoT	Smart Camera	Connected physical device
OT	PLC, SCADA	Physical process control

Example:

IT

Laptop → Server → Database

IoT

Mobile → Wi-Fi → Smart Camera

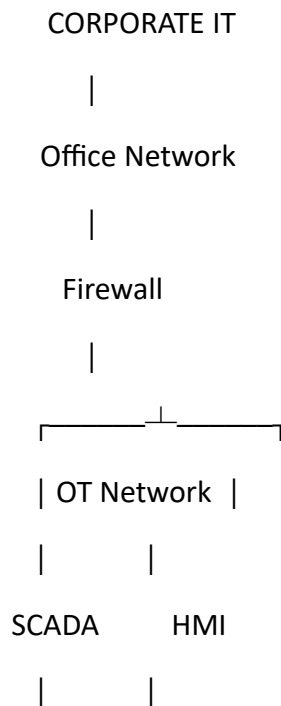
OT

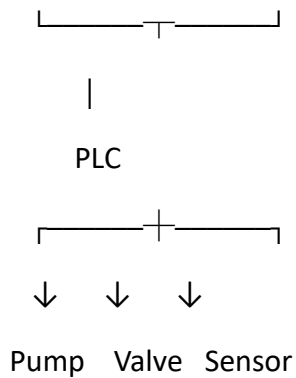
SCADA → PLC → Motor

4. Ek factory ka complete example

Suppose ek water-treatment factory hai.

Architecture kuch aisa ho sakta hai:





Yahan:

- **SCADA** = monitoring/control software
- **HMI** = Human Machine Interface
- **PLC** = industrial controller
- **Sensor** = measurement
- **Pump/Valve** = physical equipment

5. PLC ko beginner language mein samjho

PLC ko tum **industrial computer** samajh sakte ho.

Normal computer:

Keyboard



Computer



Application

PLC:

Sensor



PLC



Machine

Example:

Water Level Sensor



PLC



Water Pump

Logic:

IF water_level < minimum

THEN pump = ON

IF water_level >= maximum

THEN pump = OFF

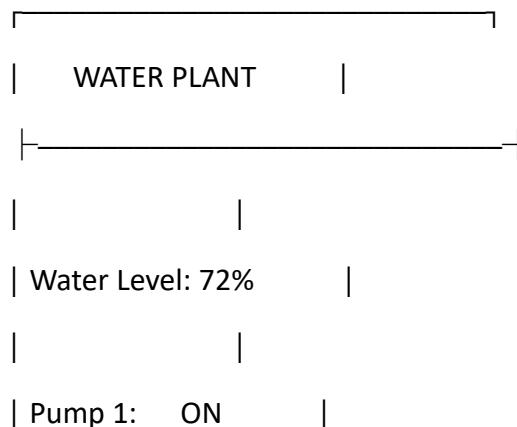
Yaani PLC programmed rules ke according physical equipment operate karta hai.

6. HMI kya hai?

HMI = **Human Machine Interface**

Operator ko machine/process ki information screen par dikhata hai.

Example:



Pump 2:	OFF	
Valve:	40%	
Status:	NORMAL	

Operator isi interface se system monitor kar sakta hai.

7. SCADA kya hai?

SCADA:

Supervisory Control and Data Acquisition

Simple words:

SCADA industrial process ka monitoring/control system hai.

Example:

Sensors

↓

PLC

↓

SCADA Server

↓

Operator Screen

SCADA operator ko:

- temperature
- pressure
- water level
- motor status
- valve status

jaise information dikha sakta hai.

8. IoT Ethical Hacking mein kya check karte hain?

Suppose tumhare paas **apna smart camera** hai.

Security tester ki thinking:

Camera

|

├— Hardware

├— Firmware

├— Network

├— Web Interface

├— API

├— Mobile App

└— Cloud

Har layer potential attack surface hai.

9. Practical IoT Lab — Step 1

Maan lo tumhare lab network mein:

Your Laptop = 192.168.1.10

Camera = 192.168.1.20

Router = 192.168.1.1

Pehle network discovery.

nmap -sn 192.168.1.0/24

Example:

Nmap scan report

192.168.1.1

192.168.1.10

192.168.1.20

192.168.1.30

Tum identify karte ho:

192.168.1.20 = Camera

10. Step 2 — Ports identify karna

Authorized camera par:

nmap 192.168.1.20

Example:

PORT STATE

80/tcp open

443/tcp open

554/tcp open

Ab question:

Port 80?

Generally HTTP.

Port 443?

HTTPS.

Port 554?

Often RTSP/video streaming.

11. Service detection

Ab:

nmap -sV 192.168.1.20

Example:

80/tcp open http

443/tcp open https

554/tcp open rtsp

-sV ka simple meaning:

Running service/version identify karne ki koshish.

12. Ethical hacker yahan kya dekhega?

Suppose:

80 → HTTP

443 → HTTPS

554 → RTSP

Ab testing questions:

Authentication

Kya login required hai?

Encryption

Sensitive data encrypted hai?

Authorization

Normal user admin function access kar sakta hai?

Configuration

Unnecessary services enabled hain?

Firmware

Firmware outdated hai?

13. IoT ka sabse common problem: Default Credentials

Suppose manufacturer device setup karta hai:

Username: admin

Password: admin

Aur user password change nahi karta.

Security finding:

Finding:

Default credentials remain enabled.

Risk:

Unauthorized access may be possible.

Recommendation:

Force password change during initial setup.

Important: Random public devices ke passwords guess karna ethical testing nahi hai. Apne lab device par test karo.

14. IoT Firmware kya hota hai?

Firmware ko simple language mein:

Device ke andar chalne wala low-level software.

Example:

Smart Camera

|

└─ Hardware

|

└─ Firmware

└─ Linux

└─ Drivers

└— Applications

└— Configuration

Firmware mein vulnerabilities ho sakti hain.

Security tester commonly check karta hai:

- outdated components
 - insecure configuration
 - hardcoded secrets
 - unnecessary services
 - weak cryptography
 - unsafe update mechanism
-

15. IoT mein API kya hai?

Suppose mobile app camera se baat karti hai:

Mobile App

↓

API

↓

Camera/Cloud

Example conceptual request:

GET /api/camera/status

Response:

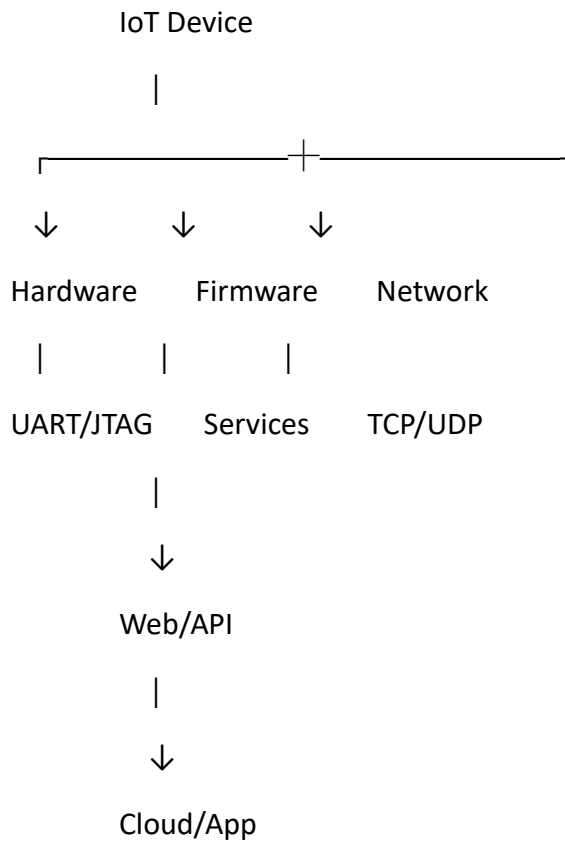
```
{  
  "camera": "online",  
  "temperature": 31  
}
```

Ethical hacker check karega:

Kya unauthorized user API access kar sakta hai?

Ye **authorization testing** ka example hai.

16. IoT ka practical attack-surface map

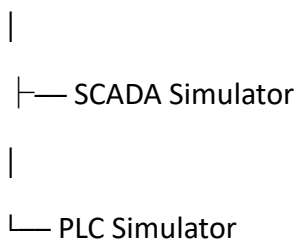


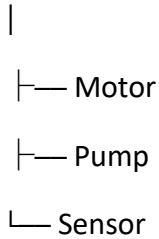
Isliye IoT security sirf nmap chalana nahi hai.

17. Ab OT practical example

Ab ek safe **OT simulator/lab** imagine karo.

Laptop





Real factory ki jagah simulator use karo.

18. Industrial protocols

OT security mein protocols important hain.

Examples:

- Modbus
- DNP3
- OPC UA
- EtherNet/IP
- PROFINET

Beginner ke liye **Modbus** se start karna relatively easy hai.

19. Modbus ko simple language mein samjho

Imagine PLC ke andar registers hain:

Register 100 → Temperature

Register 101 → Pressure

Register 102 → Motor Status

SCADA PLC se data request karta hai.

Conceptually:

SCADA

|
| "Register 100 ka value batao"

↓

PLC

|

| "72"

↓

SCADA

SCADA screen:

Temperature = 72°C

20. OT ethical hacking mein first step

Same IT methodology:

Discover

↓

Identify services

↓

Identify protocols

↓

Understand architecture

↓

Check authentication

↓

Check authorization

↓

Check configuration

↓

Report

But OT mein **safety** extra important hai.

21. OT network discovery

Authorized lab mein:

```
nmap -sn 192.168.10.0/24
```

Suppose:

192.168.10.1 Firewall

192.168.10.10 SCADA

192.168.10.20 HMI

192.168.10.30 PLC

Tum architecture bana sakte ho:

Firewall

|

|— SCADA

|

|— HMI

|

└─ PLC

22. PLC service discovery

Lab PLC par:

```
nmap -sV 192.168.10.30
```

Suppose:

502/tcp open

Port **502** commonly Modbus TCP ke liye associated hota hai.

Ab tester ka question:

Is industrial service appropriately protected?

23. OT mein dangerous mistake kya hai?

Suppose tum production PLC par aggressive scan kar do:

`nmap -A <production PLC>`

Ye blindly karna good idea nahi hai.

Why?

OT systems sometimes:

- old hardware use karte hain
- fragile services run karte hain
- availability critical hoti hai
- reboot/communication issues tolerate nahi karte

Isliye OT pentesting mein:

Safety > Aggressive testing

24. IT hacking aur OT hacking ka major difference

IT

Objective:

Get Data

Get Account

Get Access

OT

Objective could involve:

Process disruption

Equipment control

Safety impact

Production downtime

Isliye OT testing carefully planned hoti hai.

25. Example: IT vs OT impact

IT example

Employee laptop compromise:

Laptop



Data theft

Impact:

Confidentiality problem.

OT example

Industrial controller compromise:

PLC



Machine



Physical process

Potential impact:

Production, equipment, or safety could be affected.

Isliye OT cybersecurity mein **Safety** ka importance bahut high hai.

26. CIA Triad vs OT

Traditional cybersecurity:

C — Confidentiality

Data secret rahe.

I — Integrity

Data change na ho.

A — Availability

System available rahe.

OT mein often priority heavily depends on the process, but generally:

Safety



Availability



Integrity



Confidentiality

Ye universal rule nahi hai, but OT mein availability/safety ka importance IT se different ho sakta hai.

27. Network segmentation

OT security ka very important concept.

Bad architecture:

Internet



Office Network



PLC

Better:

Internet



Firewall



IT Network



Firewall / DMZ



OT Network



PLC

Goal:

IT side compromise hone par attacker directly PLC tak na pahunch sake.

28. DMZ kya hai?

DMZ ko simple words mein:

IT aur OT ke beech controlled middle zone.

Example:

Corporate IT



Firewall



DMZ



Firewall

|

↓

OT

|

↓

PLC

Ye segmentation risk reduce karne mein help karta hai.

29. Wireshark ka practical use

IoT/OT security mein **Wireshark** bahut useful hai.

Suppose tumhare lab mein:

SCADA ↔ PLC

Wireshark capture start karo.

Tum packets mein dekh sakte ho:

Source

Destination

Protocol

Length

Information

Example:

192.168.10.10 → 192.168.10.30

TCP

502

Ab tum samajhne ki koshish kar sakte ho:

Kaunsa device kis service se communicate kar raha hai?

30. IoT traffic example

Smart sensor:

Sensor → Gateway

Traffic capture mein:

MQTT

TCP

1883

MQTT IoT environments mein commonly used messaging protocol hai.

Security tester questions:

- Is authentication enabled?
 - Is encryption enabled?
 - Are unauthorized clients blocked?
 - Are credentials protected?
-

31. MQTT simple example

Imagine:

Temperature Sensor

|

↓

MQTT Broker

|

↓

Dashboard

Topic:

factory/room1/temperature

Sensor publish karta hai:

factory/room1/temperature = 28

Dashboard subscribe karta hai.

Publisher → Broker → Subscriber

Ethical hacker check karega:

Kya unauthorized client sensitive topic subscribe kar sakta hai?

32. IoT practical checklist

Ek IoT device test karte waqt:

Network

- ☐ IP address
- ☐ Open ports
- ☐ Services
- ☐ Protocols

Authentication

- ☐ Default credentials
- ☐ Password policy
- ☐ MFA where appropriate
- ☐ Session management

Authorization

- ☐ User vs admin
- ☐ API permissions
- ☐ Device permissions

Firmware

- ☐ Version
- ☐ Updates

☐ Vulnerable components

☐ Secure boot/update

Communication

☐ HTTP vs HTTPS

☐ TLS

☐ MQTT security

☐ Certificate validation

33. OT practical checklist

Asset discovery

☐ PLC

☐ HMI

☐ SCADA

☐ Historian

☐ Engineering workstation

Network

☐ Segmentation

☐ Firewall

☐ Remote access

☐ Unnecessary services

Protocols

☐ Modbus

☐ OPC UA

☐ DNP3

☐ EtherNet/IP

Access

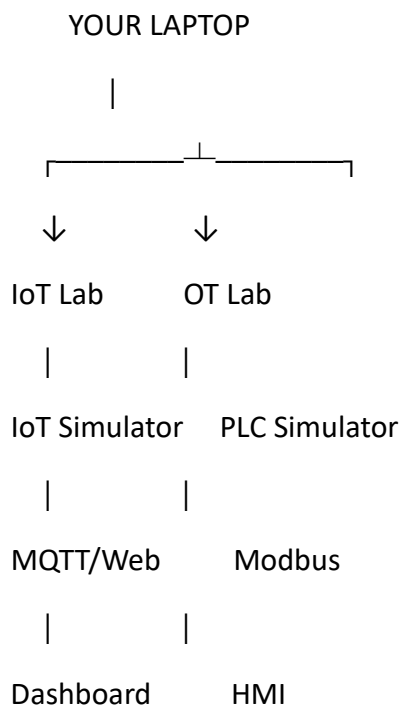
- ☐ Authentication
- ☐ Authorization
- ☐ Remote access
- ☐ Vendor access

Safety

- ☐ Can testing affect production?
 - ☐ Can testing affect safety?
 - ☐ Is there a rollback plan?
-

34. Beginner practical lab — complete flow

Tum ek safe lab bana sakte ho:



Then practice:

Lab 1

Network discovery:

`nmap -sn <YOUR-LAB-SUBNET>`

Lab 2

Service discovery:

`nmap -sV <YOUR-LAB-IP>`

Lab 3

Traffic analysis:

Wireshark



Capture



Filter



Understand protocol

Lab 4

Web/API testing:

Browser



IoT Web Interface



Authentication



Authorization

Lab 5

OT:

PLC Simulator



Modbus



SCADA/HMI

35. Vulnerability ko kaise report karoge?

Suppose lab mein tumhe default password mila.

Report:

Title:

Default Credentials Enabled

Asset:

IoT Camera

Severity:

High

Description:

The device accepts its factory-default credentials.

Impact:

An unauthorized user who obtains network access may be able to access the device.

Recommendation:

Force password change during initial setup and

disable default credentials.

Ye professional ethical hacking report ka basic format hai.

36. Ek aur important concept: Attack Surface

Attack surface ka simple meaning:

Jitne possible entry points hain, utna attack surface.

IoT:

Web

API

SSH

RTSP

MQTT

Mobile App

Cloud

Firmware

USB

OT:

SCADA

HMI

PLC

Engineering Workstation

Modbus

OPC UA

Remote Access

Vendor VPN

Security tester ka kaam:

Attack surface ko identify → understand → secure karna.

37. IoT + OT ka combined real-world scenario

Imagine smart factory:

IoT Sensors



IoT Gateway



Factory Network



SCADA



PLC



Industrial Machine

Agar network segmentation weak hai:

IoT



Factory Network



OT



PLC

Toh IoT compromise ka risk OT tak extend ho sakta hai.

Isliye:

IoT Network

|
Firewall

|
DMZ

|
Firewall

|
OT Network

|
PLC

much safer architecture hai.

38. Tools jo tumhe seekhne chahiye

Beginner

Nmap

Wireshark

Linux

Python

Burp Suite

IoT

MQTT tools

Firmware analysis tools

Serial/UART concepts

Ghidra

Binwalk

OT

Wireshark

Nmap

Modbus simulators

OpenPLC

SCADA simulators

PLC training environments

Tool se zyada important hai:

Network + protocol + architecture samajhna.

39. Tumhare liye learning sequence

Agar tum zero se start kar rahe ho, main ye order recommend karunga:

STEP 1

Networking



IP, MAC, TCP, UDP, Ports



STEP 2

Linux



STEP 3

Nmap



STEP 4

Wireshark



STEP 5

Web Security



STEP 6

Python



STEP 7

IoT Architecture



STEP 8

MQTT / HTTP / RTSP



STEP 9

Firmware Basics



STEP 10

PLC + SCADA



STEP 11

Modbus



STEP 12

OT Network Security



STEP 13

IoT + OT Pentesting

Sabse important practical progression:

Laptop → Network → Nmap → Wireshark → Web → IoT → PLC → SCADA → Modbus → OT Security

Agar tum chaho to next hum "**IoT Ethical Hacking Practical Lab – Day 1**" se start kar sakte hain, jisme main **VirtualBox/Kali Linux + vulnerable IoT simulator + Nmap + Wireshark** ko **ek-ek step, exact commands aur expected output** ke saath beginner level par karwa sakta hoon.